

NeevTime — Complete Application Report

Biometric attendance, shift, leave and payroll-input management for Indian workplaces

Prepared 18 August 2026 · reflects the deployed system as of this date

1. What NeevTime is

NeevTime collects attendance from ZKTeco-family biometric readers and from employees' phones, turns punches into scored working days, and produces the outputs an Indian employer is actually asked for: statutory registers for a labour inspection, payroll input sheets, leave balances, and an audit trail that can answer "who changed this record" in a dispute.

It is **self-hosted by design**. The data is biometric identifiers and payroll records; the system runs on a machine the customer owns, on a closed LAN if they choose, with no runtime dependency on the internet. One deployment per customer is the chosen tenancy model.

Pilot deployment: ~68 active employees across 16 departments, 5 biometric readers, ~400–900 punches/day, integrated with ERPNext.

2. Architecture and technology

Layer	Technology
Readers	ZKTeco/eSSL ADMS push protocol over HTTP (<code>/iclock</code>), clear text by design — the readers cannot follow redirects
Reverse proxy	nginx (TLS termination, HTTP→HTTPS redirect for browsers, <code>/iclock</code> exempted), self-signed certificate generated at install, persisted on a volume
API	Node.js 18 / Express, Socket.IO for live feeds
Database	PostgreSQL 15, <code>pg</code> driver; wall-clock timestamps stored as <code>timestamp without time zone</code> , always read as text (<code>to_char</code>) to prevent driver timezone reinterpretation
Client	React 18 + Vite, Tailwind CSS, Recharts; self-hosted fonts (no Google Fonts callout); ~76 screens
Employee portal	Same client, separate auth realm, mobile-first
Packaging	Docker Compose: <code>db</code> , <code>server</code> , <code>client</code> , optional <code>cloudflared</code> (outbound-only tunnel, off by default)
Scheduled work	In-process jobs: nightly recompute, nightly rotation generator, monthly leave accrual, daily backups, alert checks, photo retention

Design rules the codebase enforces

- **One source of truth per number.** Lateness and overtime are computed once, by the attendance engine, shift-aware; every report reads `attendance_daily_summary` rather than re-deriving. Tests pin this.
 - **Timezone discipline.** The configured zone (`Asia/Kolkata` by default) governs scoring, scheduling, backups and alerts — never the container clock, which is UTC. Four separate bugs taught this rule; guards now enforce it.
 - **Migrations are applied by a person** (`docker compose exec server node migrations/runner.js up`), never at boot: a schema change that can empty a table must not ride in on an unrelated deploy. `verify-deploy.sh` warns when any are pending. Additive changes self-apply via `ensureSchema` .
 - **Fixtures use the product's own door.** A feature test that writes a parallel table proves nothing; this failure happened and is now guarded against.
-

3. Installation and configuration

Install

```
git clone <repo> && cd NeevTime && ./install.sh
```

`install.sh` is the procedure — CI runs it on a clean machine on every push, then proves a punch reaches the application through nginx. It: checks Docker + Compose v2; generates `.env` (mode 600, never overwritten) with real secrets; creates the pinned external database volume; builds and starts; waits for health; prints the first administrator's password once. There are **no default credentials anywhere**: missing `JWT_SECRET` or `DB_PASSWORD` stops the stack rather than weakening it, and no `admin/admin` account exists.

Key configuration surfaces

Where	What
<code>.env</code>	<code>JWT_SECRET</code> , <code>DB_PASSWORD</code> , <code>BACKUP_EXTERNAL_DIR</code> , <code>TLS_COMMON_NAME</code> , <code>ADMIN_PASSWORD</code> (first boot only), <code>OIDC_CLIENT_SECRET</code> , <code>LDAP_BIND_PASSWORD</code> , <code>TUNNEL_TOKEN</code>
Settings → Attendance Rules	global shift start, grace, full/half-day thresholds, OT threshold
Settings → Weekend Rules	Sundays, nth-Saturdays
Settings → Employee Sign-in	login modes (local/OIDC/LDAP), issuer/client IDs, LDAP server/base DN — secrets deliberately absent from this screen
Settings → Approvals	approval chain order: <code>manager, department, hr</code>
Settings → Alerts / Email	SMTP, recipients, thresholds; test buttons send through the real pipeline
Settings → Database	schedule, retention, second-copy destination (SMB / S3 / SFTP / SharePoint, tested before saving; secrets encrypted at rest)
Timezone	governs everything date-shaped

Deployment verification

`./verify-deploy.sh` — 16 checks after every deploy: containers, health, served bundle vs container bundle (browser-cache detection), `/iclock` through the reader path, pending migrations, audit-trail noise level, last punch age, punch counts, device fleet, recent errors. Read-only; designed to say "the deploy did not work" before a user does.

4. Features

Attendance capture

- **Biometric readers** via ADMS push: enrolment sync, fingerprint/face templates, device commands with retry queue and dead-letter surfacing, per-device health.
- **Mobile punch** (employee portal): GPS + geofence validation, selfie capture (reviewable in the log with name/time/geofence verdict — anti buddy-punching without face-recognition's consent burden), photos retention-limited; failed punches delete their photo.
- Both paths converge on **one ingest** (`punch_ingest`): dedup, normalisation, placeholder employees for unknown codes, daily-summary recompute (today *and* yesterday — night shifts), live socket feed, HRMS push.

Attendance engine

- Scores each employee-day against **their assigned shift** (`employee_schedules`), falling back to global rules: lateness from grace end, half/full day, OT past threshold.
- **Night shifts**: noon-boundary day attribution — a 22:00–06:00 night is one worked day, post-midnight arrivals are late against the previous evening, mid-shift 03:00 is not a "day over".
- Statuses: Present, Half Day, Short Day, Miss Punch (direction-aware: a day ending on an entry is flagged, not silently shortened), Absent, Weekly Off, Holiday-aware; resigned employees stop accruing absences.

Shifts, schedules, rotations

- Shifts with per-shift grace, thresholds, night flag; department/employee/temporary schedules; calendar view.
- **Rotation patterns**: ordered shift sequences (week A days / week B nights), crews staggered by slot offset, generated five weeks ahead into real schedule rows nightly — hand-entered schedules always beat the generator.
- **Shift swaps**: employee proposes, colleague accepts, management countersigns through the approval machinery; approval writes two traceable one-day overrides.

Leave

- Types with quota, paid flag, encashable flag, carry-forward **with mandatory cap**; full CRUD; in-use types deactivate rather than delete.
- **Accrual engine**: quota/12 credited monthly, prorated from joining (15th rule); idempotent by setting targets, never incrementing; refuses to claw back after quota cuts. Preview-first UI.
- **Year-end**: carry-forward within cap, `lapsed` recorded (the "where did my days go" answer), runs once, refuses to re-run.
- Applications with half-days, working-day counting (weekends don't consume), balance checks; `used` derived live from approved applications so imported history counts.

Approvals

- **Single-level chain** (default): reporting manager ∪ department approvers ∪ HR — a union, so one absence never blocks a team; self-approval impossible at every level; resigned approvers skipped; the level used is recorded on each decision.
- **Multi-step flows** (opt-in per request type/department): Role/Flow/Node builder — ordered steps, node types Person / Role-with-members / Manager / Department / HR; requests advance step by step; rejection settles at any step; every step's signature recorded in `approval_actions` ; HR override (visible as such) prevents trapped requests.
- Rejections carry a reason the employee sees.

Employee portal (`/portal`)

Separate auth realm — identity from the token, structurally unable to act as anyone else. Tabs: My Attendance (+ punch card), My Leave (apply, balances), Requests (corrections + shift swaps), Approvals

(only for approvers), Shift & Holidays (own shift, location-filtered holiday list), My Profile (read-only, with reason) + monthly CSV export of own attendance.

Sign-in

- **Local:** employee sets their own password via single-use activation code (emailed, or handed on paper for mailbox-less staff); HR never knows it; HR-set passwords force a change before anything else works; forgotten-password flow leaks no employee-code existence.
- **OIDC** (Entra ID/Google/Okta): full code flow, state+nonce+audience checked, token returned in URL fragment; first sign-in matches email/UPN then binds to the immutable directory id, so UPN changes never lock anyone out.
- **LDAP** (on-prem AD): LDAPS enforced, RFC 4515 escaping, bind-as-user; app never stores the domain password. Modes combinable per site. Unmatched accounts are refused, never auto-created.

Contractors

First-class billable entities (name, contact, GST, optional rate); employees attach to one; monthly summary — headcount, hours, OT — from the same rows payroll uses; amount shown only when a rate was actually agreed; deletion refused while people are attached.

Reports & registers

- **Statutory registers:** muster roll (P/A/L/H/W marks, honest ? for no-data days), overtime register, leave register — retention-aware, with a documented verification procedure for a compliance officer.
- Daily/monthly/late-early/absent/overtime/payroll reports — one arithmetic, matching the engine, verified by a 14-check accuracy harness against hand-computed fixtures.
- **Insights:** department x month cross-tab, six-month late/OT/absence trends.
- Payroll export with half-days at 0.5 and explicit needs-review counts; CSV/Excel export on every grid; scheduled email delivery; one-click HTML/PDF prints.

Audit trail

Database triggers (not application code) record who changed what and what it said before, across employees, attendance edits, users, settings, geofences, shifts, balances, contractors, workflows. Actor travels via AsyncLocalStorage onto the pooled connection. Machine noise (heartbeats, recomputes, sync bookkeeping) is excluded by design; secrets are stripped; per-hour unattributed-row alarm catches new noise sources. Punch *inserts* are not audited (the punch is the record); punch *edits and deletions* are.

Monitoring & alerts

Email alerts through one raise/resolve pipeline (open issues never re-spam; recovery mails confirm closure): no-punches-today (the "145-day outage" catcher, with a **fire drill** that runs the real check), devices offline, command dead-letters, **stale scheduled backups** (manual dumps deliberately don't clear it), config-change notices. Live dashboards over websocket.

Backups

Nightly `pg_dump` (custom format) on the configured local-time schedule; retention-pruned; volume-persisted; **second copy off-machine** to SMB/S3/SFTP/SharePoint with encrypted credentials and pre-save destination tests; restore rehearsed and verified; download/restore through the UI.

Integrations

ERPNext bidirectional sync (attendance push, employee/leave pull) plus a generic webhook adapter; excluded-employee flags; sync logs. Payroll systems are served by file export by design — paid-API partner programs are out of scope for a self-hosted product.

5. Security posture

- No default secrets or accounts anywhere; compose refuses to start without generated values.
 - TLS on for browsers; readers isolated to the one clear-text path they require, CI-enforced.
 - Two authentication realms (admin users vs employees); portal identity structurally token-bound; RBAC middleware denies writes centrally; login lockout with policy-driven password rules applying to employees too.
 - CORS/websocket: single origin gate (same-origin or allowlist), refusals logged with both sides; foreign-origin socket attempts CI-tested.
 - Secrets: environment-only for OIDC/LDAP; destination credentials encrypted at rest; secrets stripped from audit rows; punch photos auth-gated (fetched as blobs, never bare `<img>` URLs) and retention-limited.
 - Postgres exposed on 5432 to the LAN only (documented; do not forward).
 - SQL injection: parameterised throughout; LDAP filter escaping; CSV output quoted.
 - Optional Cloudflare tunnel: outbound-only, token via environment, no inbound firewall surface.
-

6. Use cases

1. **Factory with mixed workforce** — own staff plus drivers/security/housekeeping from agencies: contractor entities answer "what do I owe agency X for August" from the same numbers as the register; readers at gates; department approvers for leave.
2. **Office on Microsoft 365** — employees sign in with their company account (MFA included, nothing stored); managers approve from their phones; monthly muster in one click.
3. **Night-shift operations** — rotation patterns generate A/B crews five weeks out; nights score as single days; swaps let workers trade dates with management countersigning.
4. **Payroll month-end** — payroll sheet with present days (half-days at 0.5), engine-computed OT, late minutes, and explicit needs-review rows; Excel export; every figure traceable to the register.

5. **Labour inspection** — muster roll, OT register, leave register produced on demand; retention windows honoured; verification procedure for the customer's compliance officer included.
 6. **Payroll dispute** — the audit trail answers who changed the record and what it said before; per-step approval signatures answer who authorised; punch photos answer who actually punched.
 7. **Air-gapped site** — no internet at runtime: local sign-in, LDAP against on-prem AD, self-hosted fonts, SMB backup target.
-

7. Quality practice

- **345+ server tests**, most needing no database; register/payroll suites against real PostgreSQL in CI; migrations applied in CI exactly as a fresh install applies them.
- **CI installs the product from scratch** on every push via `install.sh`, then proves the reader path, the websocket upgrade (browser-shaped, through nginx, over TLS), and that a foreign origin is refused.
- **76-screen browser sweep** on every push: console errors, uncaught exceptions, blank pages, *rendered error panels* (catches politely-caught failures), and a generic dialog-opening pass.
- Guard tests pin the load-bearing decisions: one arithmetic per number, live tables not dead ones, schema columns actually created, sidebar/module agreement, icon exports, tab-bar overflow.
- Accuracy harness: a fixture employee whose week is computable on paper, 14 cross-report checks.

8. Known limits (stated, not hidden)

- Face *recognition* is deliberately absent — reviewable photos only (lighter DPDP consent burden).
- Position-type workflow nodes resolve to nobody (no position→people mapping); HR override covers them.
- Register *layouts* await mark-up by a compliance officer against each state's prescribed forms; the content is verified, the form numbers are not.
- Native mobile apps deferred until remote access (tunnel + domain) makes them meaningful; the portal is mobile-web.
- Multi-tenancy branch exists but stays unmerged: one deployment per customer is the model.